Threat Analysis Report

รายงานวิเคราะห์การโจมตีเว็บเซิร์ฟเวอร์ด้วย Web shell ผ่านการทำ Log poisoning

10/10/2025

TLP:CLEAR

สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ
๑๒๐ ชั้น ๗ อาคารซี ศูนย์ราชการเฉลิมพระเกียรติ ๘๐ พรรษา ๕ ธันวาคม ๒๕๕๐
ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพมหานคร ๑๐๒๑๐ อีเมล saraban@ncsa.or.th

สารบัญ

สารบัญ 2
บทสรุปสำหรับผู้บริหาร 3
การวิเคราะห์เชิงเทคนิค 4
Technique Tactics and Procedures (MITRE ATT&CK) 6
Indicator of Compromise (IOCs) 7
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ 8
อ้างอิง (References) 10

บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้วิเคราะห์เทคนิคการโจมตีเว็บเซิร์ฟเวอร์ด้วย Web Shell และ **Nezha-agent** เพื่อติดตั้ง **Gh0st RAT** โดยกลุ่มผู้ไม่หวังดีที่มีความเชื่อมโยงกับประเทศจีน (China-Nexus threat actor) ซึ่งทาง Huntress ได้ค้นพบแคมเปญการโจมตีนี้ในช่วงของเดือนสิงหาคม 2568

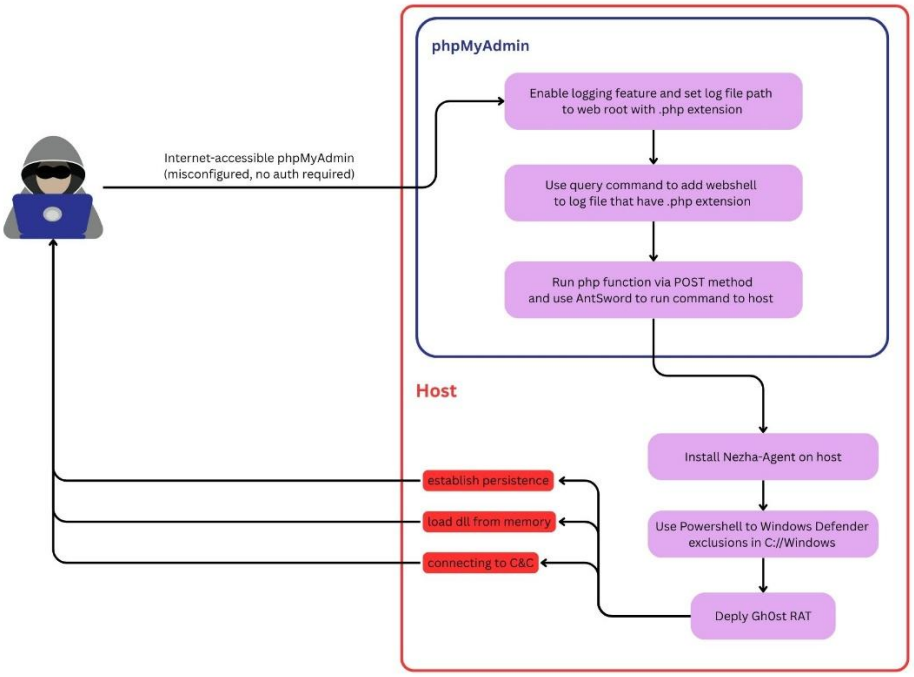
ในแคมเปญนี้ผู้โจมตีได้ใช้ประโยชน์จาก phpMyAdmin ที่ถูกเปิดเผยสู่สาธารณะและเทคนิคที่มีชื่อว่า Log poisoning (หรือ log injection) เพื่อฝัง Web shell ลงบน MariaDB general log โดยตั้งนามสกุลของไฟล์ log ให้เป็น .php และวางไว้บนโฟลเดอร์ htdocs โดย Web shell ที่ถูกฝังนั้นจะทำหน้าที่ในการจัดเตรียมและควบคุม Nezel-Agent (เครื่องมือ Open-source สำหรับการทำ server monitoring and task management) สำหรับการติดตั้ง Ghost RAT ในลำดับถัดไป

การวิเคราะห์เชิงเทคนิค

Attack Flow

1. **Initial Access:** ผู้โจมตีเข้าถึงหน้า phpMyAdmin ที่มีข้อผิดพลาดในไฟล์ตั้งค่าตั้งต้น (default configuration file) ทำให้ผู้โจมตีนั้นสามารถที่จะเข้าถึงแผงควบคุมได้โดยไม่จำเป็นต้องตรวจสิทธิ์ใด ๆ
2. **Log poisoning:** เมื่อผู้โจมตีสามารถเข้าถึงแผงควบคุมของ phpMyAdmin ได้แล้ว ผู้โจมตีได้ทำการเปิดการใช้งาน MariaDB general query logging และตั้งค่าพาทของไฟล์ log ไว้ภายใต้ web server document root (htdocs/123.php) จากนั้นผู้โจมตีได้ทำการ query คำสั่งที่เป็น PHP Web shell แบบบรรทัดเดียวลงไป เมื่อคำสั่งถูกใช้งาน Web shell ก็จะถูกบันทึกลงบนไฟล์ log ซึ่งมีนามสกุลของไฟล์เป็น .php และยังอยู่ในโฟลเดอร์ที่สามารถถูกเรียกใช้งานได้ผ่านอินเทอร์เน็ตอีกด้วย
3. **Web shell:** ตัว Web Shell นั้นจะทำหน้าที่รับค่าจากผู้ใช้งานผ่าน method POST ที่ถูกเรียกมาที่เซิร์ฟเวอร์และประมวลค่าที่ถูกส่งมาผ่านตัวแปรในรูปแบบของโค้ด PHP โดยคำสั่งที่ถูกส่งมานั้นมักจะเป็นคำสั่งที่เกี่ยวกับเครื่องมืออย่าง AntSword หรือ China Chopper ซึ่งจะเป็นกระบวนการในการส่งคำสั่งจากระบบที่ถูกโจมตีไปยังโฮสต์อีกที
4. **Nezha-Agent:** หลังจากที่ผู้โจมตีสามารถที่จะส่งคำสั่งผ่าน AntSword ซึ่งเป็น Virtual terminal ได้แล้วนั้น ผู้โจมตีจะย้ายไปยังไดเรคทอรี่ C:\Windows\Cursors และได้ทำการดาวน์โหลดไฟล์เพิ่มเติม ได้แก่ live.exe และ config.yml จาก rism.pages[.]dev โดย live.exe ได้รับการระบุเป็น Nezha-Agent ซึ่งเป็นเครื่องมือ open-source server monitoring and task management และภายในไฟล์ Config.yml นั้นยังมีการชี้ไปยังเซิร์ฟเวอร์ของผู้โจมตี (c.mid[.]al) พร้อมทั้งเปิดใช้งานพอร์ต 80 และ 22
5. **Gh0st RAT:** ผู้โจมตีจะทำการรัน Powershell เพื่อสร้างการยกเว้นของการแสกนจาก Windows Defender ในพาท C:\WINDOWS ก่อนที่จะทำการเรียกใช้งาน x.exe จากพาท C:\Windows\Cursors\ โดย x.exe ถูกวิเคราะห์ว่าเป็น Gh0st RAT ซึ่งเป็น Remote Access Trojan ที่ทำงานด้วยกันสามขั้นตอนหลัก ได้แก่
    a. **Stage 1 Loader:** Stub ที่ทำหน้าในการตั้งค่า exception handler และกระตุ้นการทำงานของ dll ที่ฝังมาด้วยกันด้วยการเรียกใช้งาน CxxThrowException
    b. **Stage 2 Dropper:** ทำการรีเวิร์ส PE blob ที่ถูกฝังไว้ จากนั้นค้นหา configuration marker ที่มีค่าเป็น null เพื่อทำการเขียนค่าลงไปใน Config byte นั้นก่อนที่จะทำการเขียนเพย์โหลดสุดท้าย

c. **Stage 3 Ghost RAT:** Remote Access Trojan แบบเต็มรูปแบบที่มีความสามารถหลากหลาย เช่น การโหลด dll จากหน่วยความจำ, สร้าง shell, อ่านเขียน Registry หรือแม้แต่การสร้างการคงอยู่ (persistence) ด้วยการสร้าง Service ปลอมและวางไฟล์ไบนารีที่เปลี่ยนชื่อแล้วไว้ที่ C:\Windows\system32\32138546.dll



[แผนภาพการโจมตี]

Technique Tactics and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Initial Access	T1190	Exploit Public-Facing Application
Execution	T1203	Exploitation for Client Execution
	T1059.001	Command and Scripting Interpreter: PowerShell
Persistence	T1543.003	Create or Modify System Process: Windows Service
Defense Evasion	T1562.001	Impair Defenses: Disable or Modify Tools
Command and control	T1071.001	Application Layer Protocol — Web Protocols

Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

SHA 256:

7b2599ed54b72daec0acfd32744c7a9a77b19e6cf4e1651837175e4606dbc958

82611e60a2c5de23a1b976bb3b9a32c4427cb60a002e4c27cadfa84031d87999

35e0b22139fb27d2c9721aedf5770d893423bf029e1f56be92485ff8fce210f3

f3570bb6e0f9c695d48f89f043380b43831dd0f6fe79b16eda2a3ffd9fd7ad16

9f33095a24471bed55ce11803e4ebbed5118bfb5d3861baf1c8214efcd9e7de6

IP Address:

54.46.50[.]255

45.207.220[.]12

172.245.52[.]169

Domain:

c.mid[.]al

gd.bj2[.]xyz

URL:

hxxps://rism.pages[.]dev/microsoft.exe

แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- ตรวจสอบการเข้าถึง phpMyAdmin: ตรวจสอบว่าหน้าแผงควบคุม phpMyAdmin นั้นสามารถเข้าถึงได้ผ่านสาธารณะโดยไม่จำเป็นหรือไม่
- ตรวจสอบการเปลี่ยนแปลงค่า: ตรวจสอบว่าค่า SET GLOBAL general_log_file และ general_log ของ MariaDB/MySQL โดยเฉพาะอย่างยิ่งเมื่อพาทไฟล์ชี้ไปที่โฟลเดอร์ Webroot หรือมีนามสกุล .php
- ค้นหาไฟล์แปลกปลอม: ค้นหาไฟล์ .php ใน Webroot ที่มีโค้ดแบบ one-liner เช่น eval($_REQUEST);

การป้องกัน (Prevention)

- นำค่า IOC ไปใช้งาน: ทำการเพิ่มการบล็อกการสื่อสารกับค่า IOC ที่เป็น C2 IP Address และนำค่า File hash ไปใช้งานกับระบบที่สามารถตรวจจับค่า file hash ได้
- จำกัดการเข้าถึง: จำกัดการเข้าถึงหน้าแผงควบคุม phpMyAdmin โดยให้เข้าถึงเฉพาะ IP Address ใน allowlist และบังคับให้ยืนยันตัวตนเท่านั้น
- ใช้โซลูชัน Endpoint Security: ติดตั้งโซลูชัน EDR ที่สามารถตรวจจับพฤติกรรมที่ผิดปกติ เช่น การโหลด DLL โดยใช้ exception handler และรูปแบบ PE ฝังที่ถูกกลับลำดับ (reversed embedded PE)

การรับมือ (Response)

- ตรวจสอบเบื้องต้น: ตรวจสอบ log ของ Web Server ว่ามีการเรียกใช้งานไฟล์ php ที่ไม่ปกติหรือไม่, ตรวจสอบการตั้งค่าของระบบ logging ว่ามีการตั้งพาทไปยังไดเรคทอรี่ที่เป็น Web root หรือว่านามสกุลไฟล์เป็น .php หรือไม่
- แยกอุปกรณ์ที่ติดเชื้อ: หากตรวจพบการบุกรุก ให้รีบตัดการเชื่อมต่อจากเครือข่ายทันทีเพื่อป้องกันการติดต่อกับ Command and Control พร้อมหยุดการทำงานของเซอร์วิสหรือ dll แปลกปลอม
- เก็บหลักฐานทางดิจิทัล: รักษาสภาพของเครื่องที่ติดเชื้อไว้เพื่อการวิเคราะห์หาสาเหตุและสืบสวน (Digital Forensics)
- กู้คืนระบบ: กู้คืนระบบจากไฟล์ Backup ที่มีความปลอดภัย และได้รับการยืนยันว่าได้แก้ไขการตั้งค่าที่ไม่ปลอดภัยเรียบร้อยแล้วก่อนนำระบบกลับสู่การใช้งาน

- รายงานเหตุการณ์: แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงานด้านความมั่นคงปลอดภัยไซเบอร์

อ้างอิง (References)

1. CYBLE treat Advisory
2. Huntress article "The Crown Prince, Nezha: A New Tool Favored by China-Nexus Threat Actors"
   https://www.huntress.com/blog/nezha-china-nexus-threat-actor-tool

แบบประเมินรายงานข่าวกรองไซเบอร์

https://dg.th/nsexlfob51

จัดทำโดย

ฤทธิ์นภา ประเสริฐศรี

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน
ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ
โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th